

SIEM ile Log Analizi: Temel Kavramlar ve Stratejiler

Yönetici Özeti

Bu brifing belgesi, Güvenlik Operasyonları Merkezlerinin (SOC) temel taşı olan SIEM (Güvenlik Bilgileri ve Olay Yönetimi) çözümlerinin rolünü ve etkinliğini incelemektedir. SIEM, log verilerini **merkezileştirme**, ayrı olaylar arasında **korelasyon** kurma ve **geçmiş olayları** analiz etme gibi temel yetenekleriyle SOC analistlerinin verimliliğini artırır. Ağ cihazları, sunucular, bulut servisleri ve uygulamalar gibi çeşitli kaynaklardan gelen logları tek bir platformda toplayarak, araştırmalar sırasında sistemler arasında geçiş yapma ihtiyacını ortadan kaldırır. Farklı saat dilimleri ve log formatları gibi zorlukların üstesinden gelmek için zaman ve veri **normalizasyonu** kritik öneme sahiptir. Belge, Windows (WinEventLogs, Sysmon), Linux (auth.log, syslog) ve Web Uygulamaları (access logs, error logs) gibi temel sistemlerden gelen logların analizine yönelik özel stratejileri detaylandırarak, analistlerin kötü amaçlı faaliyetleri, yetki yükseltme girişimlerini ve diğer siber tehditleri tespit etmelerine olanak tanıyan temel veri kaynaklarını ve yöntemlerini ortaya koymaktadır.

SIEM'in Temel Faydaları

SIEM çözümleri, bir Güvenlik Operasyonları Merkezi (SOC) analistinin günlük iş akışında merkezi bir rol oynar. Bu araçların değeri, analiz süreçlerini önemli ölçüde geliştiren temel yeteneklerinden kaynaklanmaktadır.

Merkezileştirme

SIEM'in en temel faydalarından biri **merkezileştirmedir**. Bir analistin ağ cihazları, bulut hizmetleri, kimlik sağlayıcılar ve daha fazlası gibi farklı yerlerdeki logları kontrol etmek yerine, SIEM tüm bu verileri tek bir yerde toplar. Bu, bir araştırma sırasında analistin sistemler arasında geçiş yapma zorunluluğunu ortadan kaldırır. Her şeyin tek bir çözümde mevcut olması, iş akışını çok daha sorunsuz ve verimli hale getirir.

Korelasyon

SIEM'in bir diğer temel gücü, ayrı olayları birbirine bağlayarak ve bir bulmacanın parçaları gibi birleştirerek tam bir resim oluşturma yeteneği olan **korelasyondur**. Örneğin, bir SIEM'de dahili ağ keşif etkinliği hakkında bir uyarı alındığını düşünelim. Eldeki tek bilgi, taramayı gerçekleştiren ana bilgisayarın IP adresidir. Bu uyarı, Saldırı Tespit Sistemi (IDS) loglarından gelmektedir. Bu bilgi tek başına yeterli değildir. Anlamlı bir sonuca ulaşmak için veriyi zenginleştirmek, IP adresinin hangi cihaza ait olduğunu ve bu etkinliği kimin başlattığını bulmak gerekir. Korelasyon, bu farklı veri noktalarını birleştirerek analistin olayı bütünsel olarak anlamasını sağlar.

Geçmiş Olaylar

SIEM, sadece mevcut faaliyetleri değil, aynı zamanda geçmiş olayları da inceleme imkanı sunar. Bu, daha önce başlamış ancak o sırada fark edilmemiş olabilecek kalıpları veya tehditleri tespit etmeye yardımcı olur. Örneğin, bir kullanıcı için olağandışı bir oturum açma konumu hakkında bir uyarı alındığında, analist geçmiş loglara bakarak bu kullanıcının daha önce bu konumdan veya IP'den oturum açıp açmadığını kontrol edebilir. Bu, kullanıcının

davranış kalıplarını belirlemeye ve etkinliğin kötü amaçlı bir girişim mi yoksa meşru bir eylem mi olduğunu değerlendirmeye yardımcı olur.

SIEM'deki Temel Zorluklar

Analistlerin SIEM'de çalışırken karşılaştığı bazı yaygın zorluklar, verinin doğası ve işlenmesiyle ilgilidir.

Zaman Dilimi Sorunları

Farklı log kaynaklarından gelen verilerde zamanın nasıl kaydedildiği önemli bir zorluktur. Loglar farklı saat dilimlerindeki sistemlerden gelebilir; bazıları UTC, bazıları yerel saat diliminde olabilir ve bazıları ise hiçbir saat dilimi bilgisi içermeyebilir. Analistin yerel saati ile SIEM'de ayarlanan saatin farklı olabileceğini anlamak önemlidir. Örneğin, bir analist UTC-2 saat diliminde çalışırken Splunk SIEM'deki loglar UTC+2'ye normalleştirilmiş olabilir. Analist için saat 17:00 iken, aynı loglar Splunk'ta 13:00 olarak görünebilir. Bu, logların dört saat geç alındığı anlamına gelmez; sadece zaman ayarlarındaki bir farktır. Olayları analiz ederken hangi saat dilimleriyle çalışıldığının farkında olmak, neyin ne zaman gerçekleştiğini doğru anlamak için kritik bir fark yaratabilir.

Log Normalizasyonu

Farklı loglar JSON, XML veya düz metin gibi çeşitli formatlarda gelir. Her sistem, olayları kendi yöntemine göre, farklı alan adları ve yapılar kullanarak kaydeder. **Normalizasyon**, tüm bu farklı formatları tek ve tutarlı bir yapıya dönüştürme işlemidir. Bu sayede loglarla çalışmak kolaylaşır. Analistler, her şeyi SIEM içinde standart bir şekilde görüntüleyebilir, bu da olayları arama, filtreleme ve ilişkilendirmeyi çok daha basit hale getirir. Normalizasyon olmadan, her log kaynağı tamamen farklı bir bulmacayı çözmek gibi olurdu.

Log Kaynak Türleri

SIEM'e gönderilen veriler, kaynağına göre çeşitli kategorilere ayrılır. | Kaynak Türü | Açıklama | Örnekler || ----- | ----- || **Ana Bilgisayar Tabanlı** | Organizasyon içindeki iş istasyonları ve sunucular gibi bireysel cihazlardan gelir. | Web sunucuları, SQL sunucuları, DNS sunucuları, çalışan bilgisayarları. || **Ağ Tabanlı** | Güvenlik duvarları, yönlendiriciler, IDS/IPS gibi ağ cihazlarından veri toplar. Ağ genelindeki trafiği ve bağlantıları izler. | Güvenlik duvarları, yönlendiriciler, IDS (Saldırı Tespit Sistemi), IPS (Saldırı Önleme Sistemi). || **Web Tabanlı** | Kuruluşların kendi web uygulamalarından gelen loglardır. Saldırganların erişim elde etmek için kullandığı birincil yollardan biridir. | Apache, Nginx gibi web sunucularından gelen erişim ve hata logları. |

Detaylı Log Analizi

Farklı sistem türleri, siber güvenlik analizi için benzersiz ve değerli loglar üretir.

Windows Logları

Windows loglarını bir SIEM'de analiz ederken genellikle iki ana veri kaynağı kullanılır: **WinEventLogs** ve **Sysmon**. Sysmon'un log almaya başlaması için ayrıca kurulması ve yapılandırılması gerekir. Bu iki veri kaynağının birleştirilmesi, sistemdeki etkinliklerin net bir şekilde görülmesini sağlar.

- **WinEventLogs:** Windows Olay Logları, çok sayıda benzersiz log dosyası içerir. En bilinenleri Güvenlik (Security), Sistem (System) ve Uygulama (Application) logları olsa da, sistemde bu üçünün ötesinde 200'den fazla farklı log kanalı bulunur.
- **Güvenlik Logları (Security Logs):** Analiz için en sık başvurulanan loglardır. Kullanıcı kimlik doğrulama denemeleri, hesap oluşturma veya değiştirme, dosya ve kayıt defteri anahtarlarına erişim, süreç yürütme, sistem yeniden başlatmaları veya log temizleme ve denetim veya güvenlik politikalarındaki değişiklikler gibi etkinlikleri tespit etmek için kullanılırlar.
- **Sistem Logları (System Logs):** İşletim sistemi ve temel hizmetleri tarafından oluşturulan olayları kaydeder. Hizmetlerle ilgili çeşitli olayları, sistem düzeyindeki etkinlikleri ve potansiyel hataları tespit etmeye yardımcı olur. Bu loglar, hizmetler aracılığıyla gerçekleştirilen potansiyel kalıcılık veya yetki yükseltme girişimlerini aramak için mükemmel bir yerdir.
- **Sysmon:** Windows'ta ek ve bazı durumlarda birincil log kaynağıdır. Çok çeşitli etkinlik türlerini kaydeden ve analiz sırasında yüksek düzeyde görünürlük sağlayan son derece güçlü bir araçtır. Sysmon logları kullanılarak, analistler kötü amaçlı süreç yürütme, ağ bağlantıları, olası süreç enjeksiyonu, kayıt defteri değişiklikleri ve dosya oluşturma gibi etkinlikleri gözlemleyebilir.

Linux Logları

Linux sistemlerini bir SIEM'de analiz ederken genellikle iki temel log kaynağına odaklanılır.

- **Kimlik Doğrulama Logları (auth.log):** Kullanıcı oturum açma ve sudo kullanımı gibi kimlik doğrulamayla ilgili etkinlikleri izler. Başarısız oturum açma denemelerini, yetkisiz erişim girişimlerini veya yetki yükseltmeyi tespit etmek için kritik öneme sahiptir. Bu loglar, kullanıcıların sistemle nasıl etkileşimde bulunduğunu, özellikle oturum açma denemeleri ve ayrıcalık kullanımı konusunda anlamaya yardımcı olur.
- **Sistem Logları (syslog):** Genel sistem düzeyindeki olayları yakalar. Hizmet yeniden başlatmaları, cron işleri ve arka plan süreçleri gibi olayları izlemek için kullanılır. Bu loglar, olayların zaman çizelgesini oluştururken veya sistemin zaman içindeki davranışını anlarken faydalıdır. Genellikle kalıcılık veya yetki yükseltme girişimleriyle bağlantılı olağandışı sistem davranışlarını belirlemek için de önemlidir.

Web Uygulama Logları

Neredeyse her kuruluşun kendi web sitesi ve dolayısıyla onu çalıştıran bir web sunucusu vardır. Bu web sunucularından (Apache, Nginx vb.) toplanan loglar, siber saldırıları tespit etmek için hayati bilgiler içerir.

- **Erişim Logları (Access Logs):** Analiz için en faydalı loglardır. Web sitesi kaynaklarına yapılan istekleri içerirler. Bu loglar genellikle tarama, DDoS girişimleri, çeşitli web tabanlı saldırılar ve web kabukları gibi kötü amaçlı faaliyetlerin izlerini barındırır.
- **Hata Logları (Error Logs):** Olası arızaları veya sorunları anlamaya yardımcı olarak değerli bilgiler sağlayabilirler.